

## Table of Contents

**Status da revisão:** Rascunho de tradução assistida por máquina. Requer revisão humana de terminologia, significado, links, formatação e atualidade técnica antes de ser marcado como edição final.

**\*\* SÉRIES PRÁTICAS DE CIBERSegurança, PRIVACIDADE E CONFORMIDADE**

**ISO/IEC 27001:2022 & ISO/IEC 27002:2022**

**\*\*IsMS prático, risco, auditoria, controles e ferramentas de código aberto**

- Um manual de trabalho para gerentes, analistas júnior, estudantes, mudadores de carreira, auditores internos e equipes de segurança\*

**\*\* Alberto (Al) Leiva\*\***

Primeira edição • Julho de 2026

**• todos os 93 controles do Anexo A • risco • declaração de aplicabilidade • auditoria • certificação • provas • ferramentas • laboratórios • preparação para a carreira**

## Publicação e Aviso de Uso

Autor: Alberto (Al) Leiva

Edição: Primeira Edição, Julho 2026

Este manual educacional independente não é uma publicação ISO, consultoria jurídica, decisão de certificação, relatório de auditoria ou substituto para os padrões licenciados ISO/IEC. As publicações ISO têm direitos autorais. As descrições de controle e de cláusula aqui são resumos originais; use as normas oficiais para requisitos exatos e orientação.

ISO desenvolve padrões, mas não certifica as organizações. A certificação é opcional e é realizada por organismos de certificação. Verifique o status de acreditação, escopo, locais, versão e certificado antes de confiar em uma reivindicação de certificação.

## Uso ético e autorizado

Use ferramentas técnicas apenas em sistemas, aplicativos, redes, contas em nuvem, repositórios e dados que você possui ou estão especificamente autorizados por escrito para avaliar. Use dados sintéticos e sistemas isolados em laboratórios.

Prefácio

- Uma introdução prática à gestão da segurança da informação e à garantia baseada em provas.\*

ISO/IEC 27001 é um padrão de requisitos para estabelecer, implementar, manter e melhorar continuamente um sistema de gestão da segurança da informação. Utiliza o gerenciamento de risco para preservar a confidencialidade, integridade e disponibilidade de forma que se encaixe na organização. ISO/IEC 27002 fornece orientações de controlo detalhadas, mas não é em si uma norma de certificação.

As edições de base atuais são ISO/IEC 27001:2022 e ISO/IEC 27002:2022. ISO/IEC 27001:2022 A alteração 1:2024 acrescenta explicitamente a consideração das alterações climáticas ao contexto organizacional e observa que as partes interessadas podem ter requisitos relacionados com o clima. A emenda não significa que cada organização deve criar um programa climático; deve fazer e apoiar uma determinação fundamentada de relevância dentro do contexto ISMS.

Um ISMS bem sucedido não é uma pasta de políticas. Trata-se de um sistema de gestão funcional: líderes estabelecem direção, os proprietários de risco tomam decisões de tratamento informadas, as equipes operam controles, os testes de auditoria interna o sistema, os resultados das revisões de gestão e as ações corretivas evitam a recorrência.

Como usar este manual

Os gerentes devem começar com os capítulos 1–5 e 18–23.

Os analistas júnior devem estudar cláusulas, temas do Anexo A, testes de evidências, ferramentas, laboratório e preparação de entrevista.

Os auditores internos devem centrar-se em critérios objetivos, independência, populações completas, amostragem, resultados, medidas corretivas e acompanhamento.

As organizações que buscam certificação devem confirmar as expectativas de certificação, alteração, escopo de certificação e credenciamento com profissionais competentes.

**\*Conteúdo:\*** Este documento contém um campo nativo da tabela de conteúdos do Word e um guia de capítulo verificado. Depois de editar, clique com o botão direito do mouse no conteúdo e escolha o Campo de Atualização e, em seguida, atualize a tabela inteira.

Sumário

[Comunicação de publicação e utilização \[2\]\(#publication-and-use-notice\)](#)

[Utilização ética e autorizada \[2\]\(#ethical-and-authorized-use\)](#)

[Prefácio \[3\]\(#preface\)](#)

[Como usar este manual \[4\]\(#how-to-use-this-manual\)](#)

[Quadro de conteúdos \[4\]\(#table-of-contents\)](#)

[1. ISO/IEC 27001 e 27002 Fundações \[7\]\(#isoiec-27001-and-27002-foundations\)](#)

2. Âmbito de aplicação do ISMS e partes interessadas [8](#isms-scope-and-interested-parties)
3. Avaliação dos riscos e tratamento dos riscos [9](#risk-assessment-and-risk-treatment)
4. Declaração de aplicabilidade [10](#statement-of-applicability)
5. Documentação e provas [11](#documentation-and-evidence)
6. Cláusula 4 — Contexto da organização [12](#clause-4-context-of-the-organization)
7. Cláusula 5 — Liderança [13](#clause-5-leadership)
8. Cláusula 6 — Planeamento [14](#clause-6-planning)
9. Cláusula 7 — Apoio [15](#clause-7-support)
10. Cláusula 8 — Operação [16](#clause-8-operation)
11. Cláusula 9 — Avaliação do desempenho [17](#clause-9-performance-evaluation)
12. Cláusula 10 — Melhoria [18](#clause-10-improvement)
13. Anexo A 5 Controlos organizacionais [19](#annex-a-5-organizational-controls)
- 14) Anexo A 6 Pessoas que controlam [22](#annex-a-6-people-controls)
15. Anexo A 7 Controlos físicos [23](#annex-a-7-physical-controls)
16. Anexo A 8 Controlos tecnológicos [24](#annex-a-8-technological-controls)
17. Controlos de execução com ISO/IEC 27002 [26](#implementing-controls-with-isoiec-27002)
18. Testes Métricos e de Controlo [27](#metrics-and-control-testing)
19. Auditoria Interna [28](#internal-audit)
20. Revisão de gestão e ação corretiva [29](#management-review-and-corrective-action)
21. Preparação da certificação [30](#certification-readiness)
22. Ferramentas de Código Aberto [31](#open-source-tools)
  - 22.1 Assistente CISO [31](#ciso-assistant)
  - 22.2 Comunidade SimpleRisk [31](#simplerisk-community)
  - 22.3 Wazuh [31](#wazuh)
  - 22,4 osquery [32](#osquery)
  - 22.5 OpenSCAP [32](#openscap)
  - 22.6 Greenbone Community Edition [32](#greenbone-community-edition)
  - 22,7 Nmap [32](#nmap)

22.8 Trivy [32](#trivy)

22.9 OWASP ZAP [33](#owasp-zap)

22.10 Keycloak [33](#keycloak)

22.11 DefectDojo [33](#defectdojo)

22.12 AIDE [33](#aide)

22.13 Lynis [33](#lynis)

22.14 Agente de política aberta [33](#open-policy-agent)

23. Manual do SGSI para gerentes [35](#managers-isms-playbook)

24. Guia de carreira do analista júnior [36](#junior-analyst-career-guide)

24.1 Trabalho júnior típico [36](#typical-junior-work)

24.2 Valor dos empregadores de competências [37](#skills-employers-value)

25. Laboratório Fictício e Portfólio [38](#fictional-laboratory-and-portfolio)

26. Plano de aprendizagem de trinta dias [39](#thirty-day-learning-plan)

27. Preparação da entrevista [40](#interview-preparation)

27.1 O que é um ISMS? [40](#what-is-an-isms)

27.2 ISO 27001 versus 27002? [40](#iso-27001-versus-27002)

[27.3 O que é o SoA? [40] (#what-is-the-soa)] (#what-is-the-soa)

27.4 Todos os controlos do anexo A são obrigatórios? [40](#are-all-annex-a-controls-mandatory)

27.5 Como se testa um controlo? [40](#how-do-you-test-a-control)

27.6 O que é uma não conformidade? [40](#what-is-a-nonconformity)

[27.7 O que mudou em 2024? [40] (#what-changed-in-2024)] (#what-changed-in-2024)

27.8 O que pode um analista júnior concluir com segurança? [40](#what-can-a-junior-analyst-safely-conclude)

27.9 Perguntas ao empregador [40](#questions-to-ask-the-employer)

28. Modelos, Glossário, Índice e Referências [42](#templates-glossary-index-and-references)

28.1 Registo mínimo de risco [42](#minimal-risk-record)

28.2 Papel de ensaio de controlo [42](#control-test-workpaper)

28.3 Glossário [42](#glossary)

28,4 Índice de assunto [43](#subject-index)

28.5 Referências oficiais [43](#official-references)

## 1. ISO/IEC 27001 e 27002 Fundações

- Edições atuais, propósito, relacionamento e limitações importantes.\*

**Figura 1. Ciclo de melhoria contínua do ISMS**



Reconstrução localizada programática para revisão — ISO/IEC 27001/27002

*Contexto e planejamento de unidade de risco, implementação, avaliação e melhoria.*

Figura 1. Ciclo de melhoria contínua do ISMS

### \*\* Documento Função Certificação

ISO/IEC 27001:2022 ☐ Requisitos de ISMS Normativos, incluindo os controles de referência do anexo A ISO/IEC 27001:2022/Amd 1:2024 ☐ Alterações da ação climática que afetam o contexto e a consideração de partes interessadas ISO/IEC 27002:2022 ☐ Orientações de implementação para os controles de segurança da informação ISO/IEC 27005:2022 ☐ Orientação para a gestão dos riscos de segurança da informação

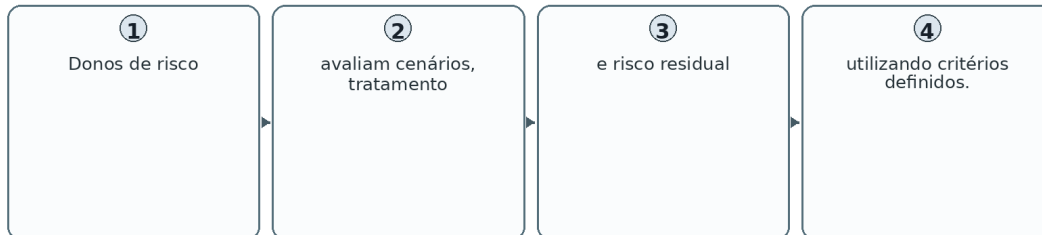
- As cláusulas 4-10 contêm requisitos que uma organização deve tratar para conformidade.
- O Anexo A enumera 93 controles de referência em quatro temas: 37 organizativos, 8 pessoas, 14 físicos e 34 tecnológicos.
- A selecção dos controles segue o tratamento de risco e as obrigações aplicáveis; o anexo A não é uma lista de verificação universal onde cada controlo deve ser sempre aplicado.
- A declaração de aplicabilidade regista os controles necessários, a justificação, o estado de execução e as exclusões justificadas do anexo A.

2. Âmbito de aplicação do ISMS e partes interessadas
  - Como definir um limite defensável para o sistema de gestão.\*
  - Identificar objetivos de negócios, produtos, serviços, processos, informações, entidades jurídicas, locais, pessoas, fornecedores, tecnologias e dependências.
  - Compreender questões internas relevantes como estratégia, cultura, habilidades, arquitetura, governança e recursos.
  - Compreender questões externas relevantes como ameaças, leis, contratos, mercados, fornecedores, condições físicas e mudança de tecnologia.
  - Determinar as partes interessadas e os requisitos relevantes, incluindo clientes, reguladores, trabalhadores, proprietários, fornecedores, comunidades e partes interessadas de certificação.
  - Considerar se as alterações climáticas são relevantes para a eficácia do ISMS e se as partes interessadas têm requisitos relacionados com o clima; documentar o raciocínio.
  - Definir limites de escopo, interfaces, exclusões, dependências e justificação em linguagem que pode ser auditada.
  - Mantenha o escopo alinhado com os inventários de ativos, processos, rede, nuvem, fornecedor e fluxo de dados.
  - **\*\* Teste de escopo\*\* \*\* Pergunta gerencial\*\* \*\* Evidência\*\***
    - ☐ Limite ☐ Quais entidades jurídicas, sites, serviços, processos e tecnologia estão incluídos? ☐ Declaração de âmbito e mapas aprovados Interfaces O que conecta o escopo a outras equipes, sistemas, fornecedores e locais? • Fluxos de dados, arquitetura, contratos, matriz de responsabilidade • Completude; Poderia informação importante ou risco ser escondido fora do limite declarado? ☐ Inventários e descobertas reconciliados Alteração O que desencadeia uma revisão do escopo? Mudar registros, aquisição e portas do produto • Relevância climática • Os efeitos climáticos ou as expectativas das partes interessadas podem afetar a disponibilidade, fornecedores, instalações, pessoas ou obrigações? • Análise de contexto, decisão, ações quando relevante

### 3. Avaliação de Risco e Tratamento de Risco

- Um método repetitivo que conecta o risco de negócios para controlar decisões.\*

## Figura 2. Fluxo de trabalho de risco de segurança da informação



Reconstrução localizada programática para revisão — ISO/IEC 27001/27002

*Donos de risco avaliam cenários, tratamento e risco residual utilizando critérios definidos.*

Figura 2. Fluxo de trabalho de risco de segurança da informação

Definir critérios de risco antes da pontuação: método de identificação de risco, escalas de verossimilhança e consequência, regras de cálculo, limiares de aceitação, tratamento necessário, escalada, frequência de revisão e autoridade do proprietário do risco. Aplicar o método de forma consistente o suficiente para produzir resultados válidos e comparáveis.

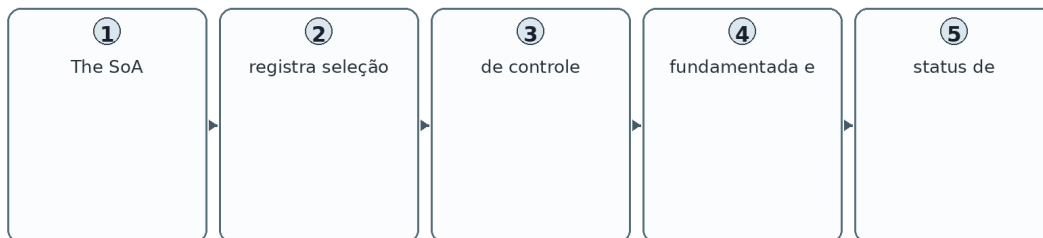
- **\*\* Campo \*\* Exemplo de conteúdo**

- ☐ Activo ou objectivo
 ☐ Portal do cliente e disponibilidade contratualmente exigida
   
Ameaça evento, roubo de credenciais seguido de acesso administrativo não autorizado ,
   
☐ Vulnerabilidade ou condição
 ☐ Inscrição fraca e sem MFA resistente a phishing
   
Consequências
 ☐ Divulgação de dados, falha, violação contratual, custo de resposta
 • Controles existentes; MFA, acesso condicional, registro, verificação de suporte;
- Risco inerente ou actual
 • Pontuação utilizando critérios de probabilidade e de consequência aprovados
 • O tratamento Modifique o risco através de autenticação mais forte e recuperação monitorada
- Proprietário e data - Nomeado proprietário responsável do risco e data-alvo
 • Risco residual; reavaliar após o tratamento; obter aprovação explícita do proprietário

## 4. Declaração de Aplicabilidade

- A ponte entre o tratamento de risco, o anexo A, outros controlos e provas de auditoria.\*

**Figura 3. Declaração de fluxo de trabalho de aplicabilidade**



Reconstrução localizada programática para revisão — ISO/IEC 27001/27002

*The SoA registra seleção de controle fundamentada e status de implementação.*

**Figura 3. Declaração de fluxo de trabalho de aplicabilidade**

- Listar os controles necessários para tratar os riscos identificados de segurança da informação e cumprir os requisitos legais, regulamentares, contratuais e comerciais.
- Compare os controles seleccionados com o anexo A, pelo que os controles de referência necessários não são ignorados.
- Registrar se cada controle do anexo A é aplicável e justificar a inclusão ou exclusão.
- Registrar claramente o estado de execução e mantê-lo em conformidade com o plano de tratamento de risco e as provas operacionais.
- Inclua controles específicos da organização quando o anexo A não abordar totalmente um risco.
- Controlar o SoA como informação documentada e atualizá-lo após mudanças de risco, escopo, legal, fornecedor, tecnologia ou controle de material.

\* \* \* \* \*  
 \* \* \* \* \*  
 \* \* \* \* \*  
 \* \* \* \* \*  
 \* \* \* \* \*  
 \* \* \* \* \*

Exemplo 8.15 de logging Sim Necessário para detecção, investigação e obrigações Exemplo 7.9 ativos off-premises Sim Sim Sim O pessoal remoto e de viagem usa dispositivos da empresa ☐

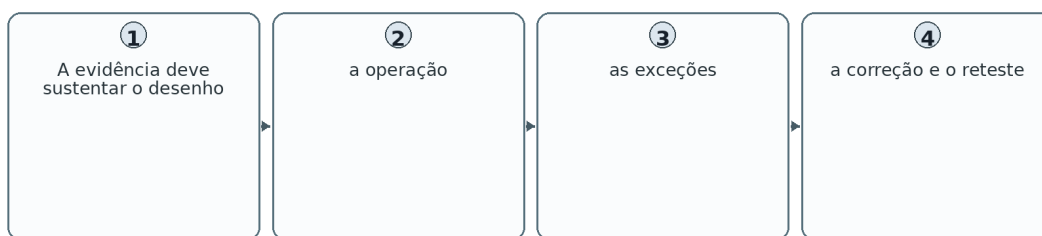


Controle de organização de exemplo Sim ☐ Risco específico de segurança do produto requer lançamentos assinados Exclusão de exemplo A tecnologia ou o cenário descrito estão ausentes do âmbito controlado

## 5. Documentação e Evidência

- Como manter informações documentadas úteis sem criar burocracia.\*

**Figura 4. Cadeia de exigência à evidência**



Reconstrução localizada programática para revisão — ISO/IEC 27001/27002

*A evidência deve sustentar o desenho, a operação, as exceções, a correção e o reteste.*

Figura 4. Cadeia de exigência à evidência

### Documento ou registo Purpose Controle

O escopo do ISMS define contornos e interfaces . Aprovado, atual, consistente com a realidade . Aprovado, comunicado, revisto O método de risco e o registo mostram a avaliação e as decisões repetíveis . Critérios aplicados de forma consistente; os proprietários aprovam o risco residual .

- Plano de tratamento de risco • Rastreia ações, proprietários, recursos e datas ☐ Declaração de Aplicabilidade • Explica a selecção e o estado de controlo • Todos os controlos do anexo A abordados; justificações suportadas • Objetivos e métricas • Mostra resultados e avaliação planejados ☐ Registos de competência e consciência ☐ Suportes de capacidade e compreensão
- Evidência operacional ☐ Mostra controlos realmente operados ☐ Completo, autêntico, protegido, retido • Registos de auditoria e revisão • Apoia a supervisão e as decisões • Registos de ação corretiva • Mostra causa raiz e correção eficaz • Causa abordada, recorrência considerada, eficácia verificada

## 6. Cláusula 4 — Contexto da organização

- Requisitos em linguagem plana, foco de verificação e evidência de exemplo.\*

☐ \*\* Finalidade da clausa: \*\* Contexto da organização .-----

## **\*Cláusula Plain signification Verificação de foco Exemplo evidência**

4.1 Compreender questões internas e externas que podem afetar o ISMS; considerar explicitamente se as alterações climáticas são relevantes. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento. 4.2 Identificar as partes interessadas relevantes, os seus requisitos e as suas expectativas relacionadas com o clima. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento. □ 4.3 □ Defina e mantenha o escopo ISMS, incluindo limites, interfaces, dependências, locais, tecnologia e exclusões. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento. 4.4 Criar, operar, manter e melhorar continuamente o ISMS e seus processos necessários. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento.

Use o texto oficial licenciado ISO/IEC 27001 para requisitos normativos exatos. Este manual parafraseia conceitos para a educação e não substitui o padrão.

Emenda:\*\* Determinar explicitamente se as alterações climáticas são relevantes para o contexto ISMS e reconhecer que as partes interessadas relevantes podem ter requisitos relacionados com o clima. Mantenha a evidência do raciocínio e qualquer ação resultante. O que é que se passa?

## **7. Cláusula 5 — Liderança**

- Requisitos em linguagem plana, foco de verificação e evidência de exemplo.\*

O objetivo da Cláusula:\*\* Liderança .—————

## **\*Cláusula Plain signification Verificação de foco Exemplo evidência**

A gestão de topo demonstra compromisso, integra o ISMS em processos de negócios, fornece recursos e apoia a melhoria. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento. 5.2 Estabelecer, comunicar e manter uma política de segurança da informação adequada à organização. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento. 5.3 □ Atribuir e comunicar responsabilidades em matéria de segurança da informação e de informação. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento.

Use o texto oficial licenciado ISO/IEC 27001 para requisitos normativos exatos. Este manual parafraseia conceitos para a educação e não substitui o padrão.

## 8. Cláusula 6 — Planejamento

- Requisitos em linguagem plana, foco de verificação e evidência de exemplo.\*

### □ \*\* Finalidade da clausa: \*\* Planeamento

#### \*Cláusula Plain signification Verificação de foco Exemplo evidência

□ 6.1.1 □ Determinar riscos e oportunidades ao nível do ISMS, planejar ações, integrá-los nos processos do ISMS e avaliar a eficácia. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento. □ 6.1.2 □ Definir e aplicar critérios de risco de segurança da informação consistentes e métodos de avaliação; identificar proprietários e analisar e avaliar riscos. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento. 6.1.3 Escolha opções e controles de tratamento de risco, compare-os com o anexo A, produza a Declaração de Aplicabilidade e plano de tratamento e obtenha aprovação do proprietário de risco. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento. □ 6.2 □ Defina objetivos de segurança mensuráveis com proprietários, recursos, datas e métodos de avaliação. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento. O Plano ISMS é alterado de modo que seu propósito, consequências, recursos, responsabilidades e integridade do sistema são considerados. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento.

Use o texto oficial licenciado ISO/IEC 27001 para requisitos normativos exatos. Este manual parafraseia conceitos para a educação e não substitui o padrão.

## 9. Cláusula 7 — Apoio

- Requisitos em linguagem plana, foco de verificação e evidência de exemplo.\*

### □ \*\* Finalidade da clausa: \*\* Suporte

#### \*Cláusula Plain signification Verificação de foco Exemplo evidência

7.1 Fornecer pessoas, financiamento, tecnologia e outros recursos necessários pelo ISMS. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento. Defina necessidades de competência, lacunas próximas, avalie resultados e mantenha evidências. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento. Assegura-te que as pessoas compreendem a política, a sua contribuição e as consequências da não conformidade.

Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento. 7.4 Planeje o que, quando, com quem e como a organização se comunica interna e externamente. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento. Criar, aprovar, identificar, proteger, distribuir, reter e controlar informações documentadas necessárias. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento.

Use o texto oficial licenciado ISO/IEC 27001 para requisitos normativos exatos. Este manual parafraseia conceitos para a educação e não substitui o padrão.

## 10. Cláusula 8 — Operação

- Requisitos em linguagem plana, foco de verificação e evidência de exemplo.\*

□ \*\* Finalidade da clausa: \*\* Funcionamento

**\*Cláusula Plain signification Verificação de foco Exemplo evidência**

8.1 Planeje e controle processos ISMS, critérios, mudanças, trabalho terceirizado e evidências de operação adequada. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento. □ 8.2 □ Realizar avaliações do risco de segurança da informação em intervalos planejados e quando ocorrerem alterações significativas. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento. .8.3 Implementar o plano de tratamento de risco e manter a evidência de resultados. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento.

Use o texto oficial licenciado ISO/IEC 27001 para requisitos normativos exatos. Este manual parafraseia conceitos para a educação e não substitui o padrão.

## 11. Cláusula 9 — Avaliação do desempenho

- Requisitos em linguagem plana, foco de verificação e evidência de exemplo.\*

□ \*\* Finalidade da clausa: \*\* Avaliação do desempenho

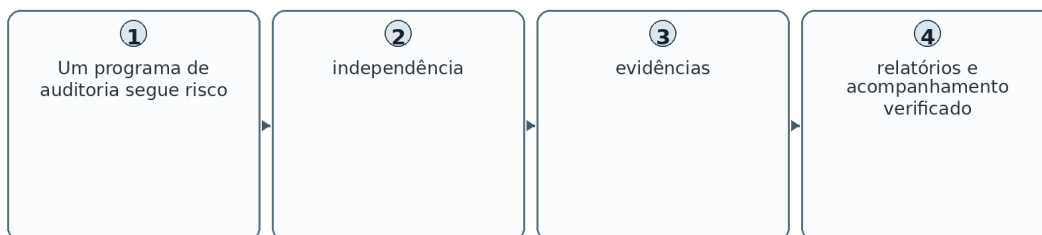
**\*Cláusula Plain signification Verificação de foco Exemplo evidência**

Defina o que monitorar e medir, como e quando fazê-lo, quem o avalia e como os resultados são retidos e analisados. Confirmar propriedade, escopo, método, aprovação, provas operacionais,

exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento. 9.2.1 Realizar auditorias internas em intervalos planejados para avaliar a conformidade com os requisitos organizacionais e ISO/IEC 27001 e implementação eficaz. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento. 9.2.2 Manter um programa de auditoria com frequência, métodos, responsabilidades, planejamento, relatórios, escopo, critérios, auditores objetivos, resultados retidos e ação corretiva oportuna. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento. □ 9.3.1 □ Top management revê o ISMS em intervalos planejados para adequação, adequação e eficácia contínuas. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento. Leia os insumos necessários, tais como ações anteriores, mudanças de contexto, necessidades interessadas, desempenho, feedback, risco, tratamento e oportunidades de melhoria. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento. □ 9.3.3 □ Registre as decisões da análise crítica pela direção sobre melhorias e mudanças necessárias no SGSI. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento.

Use o texto oficial licenciado ISO/IEC 27001 para requisitos normativos exatos. Este manual parafraseia conceitos para a educação e não substitui o padrão.

**Figura 5. Fluxo de trabalho de auditoria interna**



Reconstrução localizada programática para revisão — ISO/IEC 27001/27002

*Um programa de auditoria segue risco, independência, evidências, relatórios e acompanhamento verificado.*

Figura 5. Fluxo de trabalho de auditoria interna

## 12. Cláusula 10 — Melhoria

- Requisitos em linguagem plana, foco de verificação e evidência de exemplo.\*

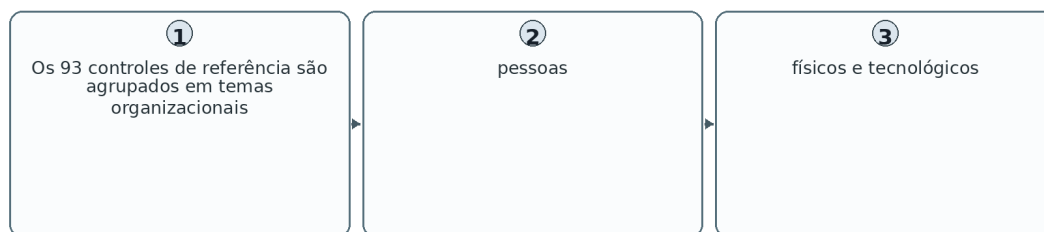
☐ \*\* Finalidade da clausa: \*\* Melhoria O que é que se passa?

### \*Cláusula Plain signification Verificação de foco Exemplo evidência

☐ 10.1 ☐ Melhorar continuamente a adequação, adequação e eficácia do ISMS. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento. Reagir a não conformidades, corrigi-las, analisar as causas, prevenir a recorrência, verificar a eficácia e manter evidências. Confirmar propriedade, escopo, método, aprovação, provas operacionais, exceções, correção e registros retidos. Políticas, registros, planos, registros, minutos, resultados, aprovações e evidências de seguimento.

Use o texto oficial licenciado ISO/IEC 27001 para requisitos normativos exatos. Este manual parafraseia conceitos para a educação e não substitui o padrão.

**Figura 6. Temas de controlo do anexo A**



Reconstrução localizada programática para revisão — ISO/IEC 27001/27002

*Os 93 controles de referência são agrupados em temas organizacionais, pessoas, físicos e tecnológicos.*

Figura 6. Temas de controlo do anexo A

## 13. Anexo A 5 Controlos organizacionais

- Resumos originais dos controlos de referência, foco de verificação e exemplos de provas.\*

## Controle\*\* Controle\*\* Significado prático\*\* Foco de verificaçãoExemplo de evidência

Manter políticas de segurança da informação aprovadas. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 5.2 Definir funções e responsabilidades de segurança. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ ☐ 5.3 ☐ Funções conflitantes separadas. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 5.4 Requerer que os gestores executem as responsabilidades de segurança. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ Manter o contato apropriado com as autoridades. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ Participe de grupos de segurança relevantes e fóruns profissionais. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 5.7 ! Coletar e usar a inteligência de ameaça. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ ☐ 5.8 ☐ Criar segurança na gestão de projetos. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ Informações de inventário e ativos associados. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 5.10 Definição de regras de uso e manuseio aceitáveis. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 5.11 Recuperar ativos organizacionais quando os papéis terminarem ou mudarem. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ ☐ 5.12 ☐ Classificar informações de acordo com a necessidade e risco. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ ☐ 5.13 ☐ Informação do rótulo consistente com a classificação. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 6.14 Proteger as transferências de informação. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ • 5.15 • Estabelecer regras de acesso-controle. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 5.16 Gerenciar identidades ao longo de seu ciclo de vida. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 5.17 . Proteger informações de

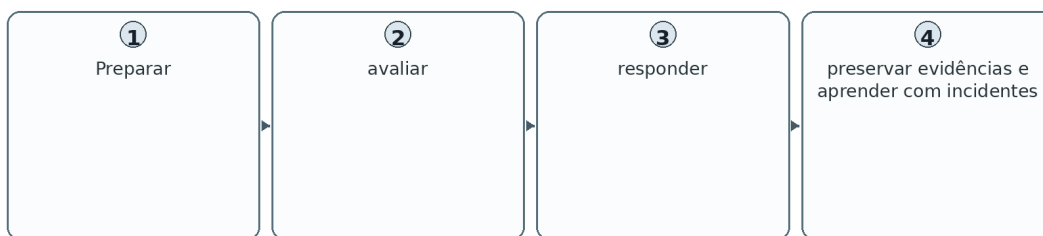
autenticação. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 5,18 Aprovar, rever, modificar e remover direitos de acesso. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 5.19 Gerenciar risco de segurança nas relações de fornecedores. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ Inclua os requisitos de segurança nos acordos de fornecedores. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ Gerencie o risco de segurança da cadeia de fornecimento de TIC. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ Monitorar, rever e controlar as mudanças entre fornecedores e serviços. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ ☐ 5.23 ☐ Govern aquisição, uso, gerenciamento e saída dos serviços de nuvem. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ Preparar e planejar a gestão de incidentes de segurança. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 5.25 Avaliar eventos e decidir se eles são incidentes. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ Responder a incidentes de segurança. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 5.27 Aprenda com incidentes e melhore os controles. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 5.28 Identifique, recolha, adquira e preserve a evidência. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 5.29 . Proteger a informação durante a interrupção. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ • 5.30 ☐ Preparar as TIC para apoiar a continuidade do negócio. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 5,31 Identifique e atenda aos requisitos legais, regulamentares e contratuais. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 5,32 Proteger os direitos de propriedade intelectual. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ ☐ 5.33 ☐ Proteger os registros durante todo o seu ciclo de vida. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ ☐ 5.34 ☐ Proteger a privacidade e as



informações pessoalmente identificáveis. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 5.35 ☐ Organize avaliações independentes da segurança da informação. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ • 5.36 • Verificar o cumprimento das políticas de segurança, regras e normas. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ Manter procedimentos operacionais documentados. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐

**Regra da selecção: \*\* O anexo A é um conjunto de referência utilizado para verificar se os controlos necessários não foram ignorados. A organização pode precisar de outros controlos. Qualquer inclusão ou exclusão deve ser justificada através de tratamento de risco e registada na Declaração de Aplicabilidade. ☐**

**Figura 7. Gestão de incidentes de segurança**



Reconstrução localizada programática para revisão — ISO/IEC 27001/27002

*Preparar, avaliar, responder, preservar evidências e aprender com incidentes.*

Figura 7. Gestão de incidentes de segurança

## 14. Anexo A 6 As pessoas controlam

- Resumos originais dos controlos de referência, foco de verificação e exemplos de provas.\*

## Controle\*\* Controle\*\* Significado prático\*\* Foco de verificaçãoExemplo de evidência

☐ 6.1 ☐ Candidatos de tela e pessoal de acordo com a lei, o papel e o risco. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 6.2 Incluir responsabilidades de segurança em termos de emprego. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 6.3 ☐ Fornecer consciencialização, educação e formação baseadas em funções. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 6.4 Opere um processo disciplinar justo e comunicado. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 6.5.5 Gerenciar os deveres de segurança após a cessação ou mudança de função. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 6.6 Use acordos adequados de confidencialidade ou não divulgação. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 6.7 Proteger a informação durante o trabalho remoto. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 6.8 Tornar a comunicação de eventos de segurança fácil e oportuna. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐

**Regra da selecção:\*\* O anexo A é um conjunto de referência utilizado para verificar se os controlos necessários não foram ignorados. A organização pode precisar de outros controlos. Qualquer inclusão ou exclusão deve ser justificada através de tratamento de risco e registada na Declaração de Aplicabilidade. ☐**

## 15. Anexo A 7 Controlos físicos

- Resumos originais dos controlos de referência, foco de verificação e exemplos de provas.\*

## Controle\*\* Controle\*\* Significado prático\*\* Foco de verificaçãoExemplo de evidência

Defina e proteja perímetros de segurança física. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ ☐ 7.2 ☐ Controle a entrada física. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 7.3 Escritórios seguros, quartos e instalações. Confirmar risco ou obrigação, design,

proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ Monitorar instalações para acesso físico não autorizado. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 7.5 Proteger contra ameaças físicas e ambientais. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ Aplicar regras de trabalho para áreas seguras. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ Use práticas claras e de tela clara. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ Local e proteger o equipamento apropriadamente. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 7.9 Proteger os activos utilizados fora das instalações organizacionais. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 7.10 Gerencie os meios de armazenamento ao longo de seu ciclo de vida. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 7.11. Proteger utilitários de suporte. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ Proteger a energia e o cabeamento de dados. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 7.13 h Mantenha o equipamento com segurança. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 7.14 ☐ Eliminar ou reutilizar equipamentos com segurança. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐

**Regra da selecção: \*\* O anexo A é um conjunto de referência utilizado para verificar se os controlos necessários não foram ignorados. A organização pode precisar de outros controlos. Qualquer inclusão ou exclusão deve ser justificada através de tratamento de risco e registada na Declaração de Aplicabilidade. ☐**

16. Anexo A 8 Controlos tecnológicos

- Resumos originais dos controlos de referência, foco de verificação e exemplos de provas.\*

**Controle\*\* Controle\*\* Significado prático\*\* Foco de verificaçãoExemplo de evidência**

☐ 8.1 ☐ Dispositivos de endpoint do utilizador seguros. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ Controle os direitos de acesso

privilegiados. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 8.3 Restrinja o acesso à informação de acordo com a política. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ Controle o acesso ao código fonte e ferramentas de desenvolvimento. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ Use autenticação segura. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ • 8.6 • Gerenciar capacidade. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 8.7 ☐ Proteger contra malware. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ \* 8.8 \* Gerenciar vulnerabilidades técnicas. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 8.9 ☐ Gerenciar configurações. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 8,10, apagar informações de forma segura quando já não é necessário. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 8.11 ☐ Máscara de dados sensíveis quando apropriado. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ • 8.12 • Evite vazamento de dados. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ • 8,13 • Manter e testar backups. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 8.14 ☐ Fornecer redundância onde a disponibilidade o exija. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 8.15 Gerar, proteger, reter e rever logs. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 8,16 sistemas de monitoramento e redes para comportamento anormal. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 8.17. Sincronizar relógios. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 8.18. Controlar utilitários poderosos do sistema. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 8,19 - Instalação de software de controle em sistemas operacionais. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 8.20 ☐ Redes seguras. Confirmar risco ou obrigação, design,

proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ Serviços de rede seguros. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ Segregate redes onde necessário. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ Controle o acesso a sites externos. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ Use e gerencie a criptografia apropriadamente. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ Opere um ciclo de vida de desenvolvimento seguro. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ ☐ 8.26 ☐ Defina requisitos de segurança da aplicação. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 8.27, aplicar princípios seguros de arquitetura e engenharia. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 8.28 Use práticas de codificação seguras. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 8.29 Ou Execute testes de segurança no desenvolvimento e aceitação. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ ☐ 8.30 ☐ Controle o desenvolvimento terceirizado. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ ☐ 8.31 ☐ Ambientes de desenvolvimento, teste e produção separados. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 8.32 Gerenciar as mudanças com segurança. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 8.33 . Proteger a informação do teste. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐ 8.34 . Proteger os sistemas operacionais durante os testes de auditoria. Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição. ☐ Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação. ☐

**Regra da selecção:\*\* O anexo A é um conjunto de referência utilizado para verificar se os controlos necessários não foram ignorados. A organização pode precisar de outros controlos. Qualquer inclusão ou exclusão deve ser justificada através de tratamento de risco e registada na Declaração de Aplicabilidade. □**

## 17. Controles de implementação com ISO/IEC 27002

- Como transformar decisões de risco em controles que se encaixam na organização.\*
1. Comece com a decisão de tratamento de risco, obrigação e resultado esperado – não com uma ferramenta.
  2. Use ISO/IEC 27002 orientações e atributos relevantes para compreender finalidade, considerações de implementação e relações.
  3. Personalizar o controle às pessoas, processo, tecnologia, ambiente físico, restrições legais, e operações de negócios.
  4. Defina proprietário, escopo, gatilho, entradas, passos, saídas, registros, frequência, dependências, exceções e escalada.
  5. Avaliar se o projeto poderia razoavelmente alcançar o resultado pretendido.
  6. Implementar através de mudanças controladas e treinar pessoas afetadas.
  7. Medir operação e eficácia, investigar exceções e melhorar.
  8. Atualizar riscos, plano de tratamento, SoA, procedimentos e evidências quando o controle muda.

aceito, e itens atrasados; Reperform pontuação, trace tratamento, confirmar aprovação do proprietário e revisão; Método, registro, aprovações, tratamento e risco residual Todos os trabalhadores, privilegiados, serviços e identidades de terceiros Necessidade de teste, aprovação, MFA, revisão, mudança, inatividade, e terminação Todos os ativos e resultados Validar cobertura, priorização, exceções, prazos, correção e rescanc Inventário, varreduras, tickets, aprovações e retestes ☐ Fornecedores ☐ População completa do fornecedor; serviços críticos e alterados da amostra ☐ Teste a devida diligência, acordo, responsabilidade, monitoramento, incidente e saída Todos os eventos e incidentes reportados Todos os eventos e incidentes relatados Continuidade Processos críticos e suporte TIC Trace business needs to recovery design and exercises BIA, plans, test records, gaps and retests Todos os objetivos e medidas do ISMS. Verifique definição, qualidade dos dados, tendência, alvo, análise, decisão e ação.

- Definir critérios exatos, escopo, período, população, controle, proprietário, evidência e resultado esperado.
- Avalie o design antes da operação de teste.
- Obter a população completa e validar sua completude e precisão de forma independente.
- Selecione uma amostra baseada em risco cobrindo datas relevantes, proprietários, locais, falhas, exceções e alterações.
- Inspecionar registros, observar trabalho, entrevistar pessoal, examinar configuração, e reperformance onde prático.
- Exceções documentais como fatos ligados a critérios; não exagere ou esconda limitações.
- Atribuir correção, análise de causa raiz, proprietário, data de vencimento, proteção provisória, e escalada.
- Reteste e indicar a conclusão final e limitação restante.

## 19. Auditoria Interna

- Uma avaliação independente da conformidade e uma aplicação eficaz.\*

Mantenha um programa de auditoria que considere a importância do processo, mudança, risco e resultados anteriores.

Definir objetivo, escopo, critérios, tempo, método, amostragem, registros e relatórios para cada auditoria.

Selecionar os auditores competentes e suficientemente objectivos; os auditores não devem controlar o seu próprio trabalho sem salvaguardas.

Use o padrão licenciado, requisitos organizacionais, decisões de risco, SoA, políticas e obrigações aplicáveis como critérios.

Registrar provas e conclusões suficientemente claras de que outra pessoa competente pode compreender a base.

Reportar os resultados à gestão relevante e acompanhar as correções e ações corretivas através da revisão da eficácia.

### **Tipo de localização\*\* \*\* \*\* \*\* \*\* Resposta exigida\*\***

Conformidade A evidência suporta os critérios Oportunidade de melhoria Uma sugestão de melhoria útil que não é uma inconformidade oculta Avaliar voluntariamente e registrar decisão Não-conformidade Um ou mais requisitos não são preenchidos, corrigir, analisar a causa, agir para prevenir a recorrência e verificar a eficácia • Limitação da auditoria – Escopo, evidência, tempo, independência ou acesso restringiu a conclusão – Divulgar claramente e resolver quando possível

## **20. Revisão de Gestão e Ação Corretiva**

- Decisões de liderança que mantêm o ISMS adequado e eficaz.\*

. \*\* \*\* \*\* \*\* \*\* \*\* \*\* \*\* \*\* \*\* ☐

As ações anteriores foram concluídas e eficazes? O que mudou, incluindo a relevância climática e as necessidades das partes interessadas? Performance O que mostram métricas, objetivos, incidentes, resultados de auditoria e não conformidades? O feedback do partido interessado O que relatam os clientes, reguladores, trabalhadores, fornecedores e proprietários? Os níveis de risco, aceitação, tratamento, recursos e SoA ainda são apropriados? Oportunidades de melhoria Que mudanças a liderança deve aprovar?

- Contenha ou corrija o problema imediato.
- Determinar a extensão e se falhas semelhantes existem em outro lugar.
- Analisar a causa com provas, não culpar.
- Plano de ação proporcional ao efeito e ao risco de recorrência.
- Aplicar alterações sob a propriedade e datas de vencimento.
- Verificar a eficácia usando evidências definidas após tempo de operação suficiente.
- Atualizar risco, controles, documentos, treinamento, objetivos e SoA quando necessário.

## **21. Preparação da certificação**

- O que a certificação faz, como geralmente procede, e o que não garante.\*



**Figura 8. Caminho de certificação**



Reconstrução localizada programática para revisão — ISO/IEC 27001/27002

*A disponibilidade é seguida de avaliação de certificação e atividades de vigilância e renovação contínuas.*

Figura 8. Caminho de certificação

A certificação é opcional; as organizações podem implementar ISO/IEC 27001 sem procurar um certificado.

ISO não realiza certificação. Um organismo de certificação independente realiza auditorias de certificação.

A acreditação proporciona uma confiança adicional na competência de um organismo de certificação; verificar o âmbito de acreditação e de certificação relevantes.

A Fase 1 avalia geralmente a prontidão, o âmbito, o sistema documentado e a preparação para a auditoria de execução.

A fase 2 avalia a implementação e a eficácia em todo o âmbito definido.

As atividades de vigilância e recertificação avaliam a conformidade contínua; os pormenores devem ser confirmados com o organismo de certificação seleccionado e as regras de acreditação.

Um certificado tem alcance e tempo limite. Ele não prova que cada produto é seguro, que nenhum incidente pode ocorrer, ou que cada sistema na empresa está incluído.

### Área de preparação\*\* Verificação de aceitação\*\*

- Escopo • Claro, suportável, refletido em operações reais e intenção de certificado Método utilizado de forma consistente; registo completo; os proprietários aceitam risco residual Todos os controlos do Anexo A abordados; seleções, exclusões e status suportados • Controlos Implementados, operados tempo suficiente para produzir evidências confiáveis, e medidos • Auditoria interna • Programa e auditoria completa concluídas com provas objectivas e

seguimento • Análise de gestão • Acção correctiva; Não conformidades corrigidas; causa e eficácia abordadas Emenda ☐ Relevância climática e requisitos das partes interessadas considerados e evidenciados

## 22. Ferramentas de Código Aberto

- Links oficiais, inícios rápidos seguros, evidências e limitações.\*

### . Ferramenta . Purpose . Possível suporte .

☐ Ciso Assistant; [intuitem.github.io](https://intuitem.github.io/); ISMS, riscos, controlos, provas [SimpleRisk Community](https://SimpleRiskCommunity.com) [www.simplerisk.com](https://www.simplerisk.com) • Wazuh – [wazuh.com](https://wazuh.com) – SIEM, monitorização dos parâmetros de avaliação, MIF [.osquery](https://www.osquery.io) , [www.osquery.io](https://www.osquery.io) , Endpoint inventário e consultas , ☐ OpenSCAP [www.open-scap.org](https://www.open-scap.org) - Greenbone Community Edition - [Greenbone.github.io](https://Greenbone.github.io) - Gestão da vulnerabilidade O Nmap [nmap.org](https://nmap.org) O Activo e a descoberta do serviço Varredura de código, imagem, dependência, segredo e configuração • OWASP ZAP ☐ Keycloak [www.keycloak.org](https://www.keycloak.org) DefectDojo [www.defectdojo.org](https://www.defectdojo.org) • Monitorização da integridade dos ficheiros ☐ Lynis, [cisofy.com](https://cisofy.com), auditoria de segurança Linux ☐ Open Policy Agent [www.openpolicyagent.org](https://www.openpolicyagent.org)

Limitação crítica: \*\* Ferramentas suportam controlos e evidências; elas não seleccionam tratamento de risco, determinam conformidade, substituem auditores competentes ou certificam uma organização. Validar cobertura, qualidade de dados, configuração, permissões, atualizações e revisão humana.

(-----  
-----  
-----

### # 22.1 Assistente CISO

Objetivo: ISMS, riscos, controlos, evidências. Projeto oficial: [CISO Assistant](#)

Início rápido seguro: Implantar em um ambiente de teste isolado; criar um projeto de framework, escopo, registro de risco, ações de tratamento, proprietários e registros de evidências.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

### # 22.2 Comunidade de Risco Simples

Objetivo: Registro de risco e tratamento. Projecto oficial: [SimpleRisk Community](#)

Início rápido e seguro: Instale com segurança, defina critérios de risco, registre riscos e proprietários, escolha tratamentos, rastreie datas de vencimento e exporte relatórios revisados.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

## # 22,3 Wazuh

Objetivo: SIEM, monitorização do desfecho, MIF. Projecto oficial: [Wazuh](#)

Início rápido e seguro: Instale um gerente de laboratório e agente, confirme a inscrição, desencadeie um evento de teste autorizado, reveja o alerta e preserve a configuração e a evidência de alerta.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

## # 22,4 Osquery

Finalidade: Inventário de Endpoint e consultas. Projeto oficial: [osquery](#)

Início rápido seguro: Instale em um host de laboratório, execute consultas somente de leitura para software, usuários, processos ou configurações, agendar consultas aprovadas e cobertura de documentos.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

## # 22.5 OpenSCAP

Objetivo: Avaliação da configuração do Linux. Projeto oficial: [OpenSCAP](#)

Início rápido seguro: Selecione um perfil apropriado, escaneie um sistema de laboratório, valide os achados manualmente, registre exceções, corrija e rescan.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

## 22.6 Greenbone Community Edition

Objectivo: Gestão da vulnerabilidade. Projeto oficial: [Greenbone Community Edition](#)

Início rápido e seguro: Autorize alvos, atualize feeds, execute varreduras de laboratório autenticadas, valide cobertura e achados, atribua remediação e rescan.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

## # 22,7 Nmap

Objetivo: Descoberta de ativos e serviços. Projeto oficial: [Nmap](#)

Início rápido seguro: Use apenas em intervalos autorizados; comece com uma varredura de serviço limitada, compare resultados com inventário, investigue desconhecidos e mantenha o comando e escopo.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

## 22.8 Trivy

Objetivo: Digitalização de código, imagem, dependência, segredo e configuração. Projeto oficial: [Trivy](#)

Início rápido seguro: Examine um repositório de testes ou uma imagem de container, valide os achados, suprima apenas com aprovação e razão, corrija e reescane.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

## # 22,9 OWASP ZAP

Objetivo: Teste de aplicação na web autorizado. Projecto oficial: [OWASP ZAP](#)

Início rápido seguro: Proxy um aplicativo de treinamento, rasteje passivamente, use a varredura ativa apenas com aprovação escrita, valide resultados e remediação de registros.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

## 22.10 Keycloak

Objetivo: Identidade, MFA, papéis e logs. Projeto oficial: [Keycloak](#)

Início rápido e seguro: Crie um reino de laboratório, usuários, grupos, papéis menos privilegiados, MFA, configurações de sessão e eventos; teste os casos de joiner, movedor e leaver.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

## 22.11 DefectDojo

Objetivo: Encontrar ingestão e remediação. Projeto oficial: [DefectDojo](#)

Início rápido e seguro: Importar resultados seguros do scanner, deduplicar cuidadosamente, atribuir proprietários, definir prazos baseados no risco, anexar prova e fechar apenas após o reteste.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

## 22.12 ADEUS

Objectivo: Monitorização da integridade dos ficheiros. Projecto oficial: [AIDE](#)

Início rápido seguro: Crie uma linha de base em um host de laboratório, faça uma alteração de arquivo autorizada, execute uma verificação, investigue a diferença e proteja a linha de base.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

## # 22.13 Lynis

Objetivo: Auditoria de segurança Linux. Projeto oficial: [Lynis](#)

Início rápido seguro: Audite um anfitrião de laboratório, reveja sugestões contra o escopo e o risco, documente decisões, corrija itens selecionados e reexecute.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

## # 22.14 Open Policy Agent

Objetivo: Política como código. Projeto oficial: [Open Policy Agent](#)

Início rápido seguro: Escreva uma pequena regra de laboratório, teste de entradas permitidas e negadas, rever a política e testes, e preservar resultados como evidência de suporte.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

## 23. Manual do SGSI para gerentes

*Perguntas, painel, propriedade e decisões os gerentes devem controlar.*

O escopo do ISMS ainda está alinhado com estratégia, serviços, locais, fornecedores, uso de nuvem, pessoas e fluxos de dados?

O que mudou no contexto, partes interessadas, obrigações legais, ameaças, tecnologia ou relevância climática?

Os critérios de risco são fiáveis e os proprietários aprovam explicitamente o tratamento e o risco residual?

O SoA corresponde à implementação de controle real e ações abertas?

Os objetivos e as métricas produzem decisões em vez de painéis decorativos?

Incidentes, constatações de auditoria, exceções, ações atrasadas e falhas repetidas são agravados?

A auditoria interna e a revisão da gestão têm independência, competência, tempo e provas suficientes?

As reivindicações de certificação, escopo, acreditação e declarações do cliente são precisas?

\* \* \* \* \*

☐ Contexto e escopo ☐ São atuais os limites, dependências, partidos e mudanças? Verde / Amarelo / Vermelho Risco Os critérios são consistentes e as decisões do proprietário são oportunas? Verde / Amarelo / Vermelho O SoA e os controles estão alinhados entre seleção, status e evidência? Verde / Amarelo / Vermelho Performance - Os objetivos, métricas, incidentes e tendências impulsionam a ação? Verde / Amarelo / Vermelho Os fornecedores são controlados risco, responsabilidade, monitoramento, incidentes e saídas? Verde / Amarelo / Vermelho As auditorias são objetivas e as conclusões corrigidas de forma eficaz? Verde / Amarelo / Vermelho • Melhoramento • Causas de raiz, recorrência e lições são abordadas? Verde / Amarelo / Vermelho ☐ Certificação ☐ As reivindicações são avaliadas, atuais e suportáveis? Verde / Amarelo / Vermelho

## 24. Guia de Carreira do Analista Júnior

- Uma rota prática para ISMS, GRC, trabalho de risco, auditoria e conformidade.\*

**Figura 9. Caminho de analista ISO 27001 Júnior**



Reconstrução localizada programática para revisão — ISO/IEC 27001/27002

*Aprenda o sistema, requisitos de mapa, provas de teste, relatório claramente, e construir um portfólio honesto.*

Figura 9. Caminho de analista ISO 27001 Júnior

GRC Júnior Analisador

Analisador de conformidade ISO 27001

Analista de Controles de Segurança

Coordenador do ISMS

Analista de Risco

Associado à Auditoria Interna

Analista de Riscos de Terceiros

Analista de Garantia de Segurança

## # 24,1 Típico trabalho júnior

- Manter escopo, ativo, obrigação, fornecedor, risco, controle, SoA, evidências, achados e registros de ação.
- Recolha provas sem alterar os registos e valide a integralidade.
- Mapa riscos e requisitos para controles, proprietários, procedimentos, sistemas e provas.
- Teste amostras de acesso, mudança, vulnerabilidade, incidente, backup, fornecedor, consciência, física e controles de continuidade.
- Apoiar auditorias internas, análises de gestão, métricas, ações corretivas e preparação de certificação.
- Escreva conclusões factuais e divulgue limitações de amostragem, escopo e provas.
- Proteger informações confidenciais e permanecer dentro da autorização.

## # 24.2 Valor dos empregadores de competências

Competência\*\* Prova\*\*

(-----)

----- Os conceitos do ISMS explicam as cláusulas 4–10 e a melhoria contínua • Risco • Criar um plano de registo e tratamento consistente (SoA) Justifique seleções, exclusões, status e evidências , • Teste de evidência; Defina populações, amostras, procedimentos, exceções e retestes; ☐ Alfabetização técnica; Interpretar identidade, nuvem, registo, vulnerabilidade, backup e evidência de configuração; • Comunicação • Escrever conclusões concisas, acções e resumos de gestão Ético Use dados sintéticos, sistemas autorizados e alegações honestas

## 25. Laboratório Fictício e Portfólio

- Um ambiente de prática segura usando dados sintéticos e sistemas de laboratório autorizados.\*

Regra do laboratório:\*\* Use uma organização fictícia, dados sintéticos, sistemas isolados e ferramentas que você está autorizado a operar. Não afirme que um projeto de portfólio é uma certificação real ou auditoria do cliente. ☐ ☐

---

---

---

1. Criar uma empresa fictícia com dois produtos, um serviço de nuvem, uma força de trabalho remota, e três fornecedores.
2. Escreva uma análise de contexto de uma página, registro do partido interessado, determinação da relevância do clima e declaração do escopo.
3. Criar critérios de risco e um registro de risco de dez cenários com proprietários e decisões de tratamento.
4. Criar um plano de tratamento e SoA que aborda todos os 93 controles Anexo A com justificativas concisas e estado de implementação honesto.
5. Construa políticas de amostragem, procedimentos, objetivos, métricas, registros de ativos e fornecedores, registro de treinamento, registro de incidentes e exercício de continuidade.
6. Use algumas ferramentas de código aberto em laboratórios isolados e capturar escopo, configuração, resultados, validação, remediação e evidências de reteste.
7. Projete e execute um plano de auditoria interna contra cláusulas e controles selecionados.
8. Escreva duas não conformidades, registros de causa raiz, ações corretivas e testes de eficácia.
9. Crie minutos de gerenciamento-revisão mostrando entradas, decisões, proprietários, recursos e prazos.
10. Publique somente artefatos sintéticos e higienizados, com uma declaração clara de limitações.

O artefato de Portfólio\*\* O que demonstra\*\* ☐

---

Contexto, partidos, escopo . Cláusula 4 raciocínio e limites . • Método de risco, registro, tratamento ☐ Declaração de aplicabilidade ☐ Controle papel de teste ☐ Evidência, amostragem, exceção e conclusão Programa, plano, critérios, relatório e acompanhamento ☐ Minutos de análise de gestão • Registro de acção correctiva O Memorando de evidência da ferramenta O Alfabetismo técnico e limitações

## 26. Plano de Aprendizagem de Trinta Dias

- Uma programação focada para a construção de capacidade de nível júnior útil.\*



- **Dias\*\* \* Foco\*\* \* Entrega\*\***

1–5 ISMS, CIA, cláusulas, ISO 27001/27002 relação, âmbito de aplicação • 6–10 • Critérios de risco, cenários, avaliação, tratamento, aceitação Os temas do Anexo A e a Declaração de Aplicabilidade 15–18 Políticas, competência, comunicação, controle de documentos, operações □ 19–22 □ Métricas, monitorização, auditoria interna, revisão da gestão 23–25; Não conformidade, causa raiz, ação corretiva, melhoria; Dois registros de achados e ação corretiva; 26–28 Laboratórios de ferramentas de código aberto autorizados Dois memorandos de evidência e reteste 29–30 □ Limpeza e prática de entrevista de carteiras

## 27. Preparação da entrevista

- Respostas claras, cenários práticos e perguntas para o empregador.\*

### 27.1 O que é um ISMS?

Um sistema de gestão para controlar o risco de segurança da informação através de liderança, planeamento, operação, avaliação e melhoria contínua.

### # 27,2 ISO 27001 versus 27002?

27001 contém requisitos ISMS certificados; 27002 fornece orientação de controle detalhada e não é em si uma norma de certificação.

### # 27.3 O que é o SoA?

Um registo controlado dos controlos necessários, a justificação da inclusão ou exclusão no anexo A e o estado de execução, ligados ao tratamento e às provas.

### 27.4 Todos os controles do Anexo A são obrigatórios?

A organização deve utilizar o anexo A como verificação de referência e justificar as decisões. Controles necessários seguem tratamento de risco e obrigações; outros controles também podem ser necessários.

### # 27.5 Como se testa um controle?

Defina critérios e escopo, valide a população, amostra por risco, inspecione e reperforme evidências, exceções documentais e correção de reteste.

## # 27.6 O que é uma não conformidade?

Falha em cumprir uma exigência. Requer correção, avaliação, ação adequada e revisão de efetividade.

## # 27.7 O que mudou em 2024?

A alteração exige uma consideração explícita da relevância das alterações climáticas no contexto e observa que as partes interessadas podem ter requisitos relacionados com o clima.

## # 27.8 O que pode um analista júnior concluir com segurança?

Factos estatais apoiados por elementos de prova e âmbito definidos, divulgar limitações e evitar reclamar a autoridade de auditoria ou certificação.

## # 27.9 Perguntas para perguntar ao empregador

- Qual é o escopo ISMS certificado ou pretendido?
- Quem é o dono da aceitação do risco e do SoA?
- Como as populações de evidência são produzidas e validadas?
- Que sistemas gerem riscos, controlos, fornecedores, resultados e medidas correctivas?
- Como é mantida a independência do auditor interno?
- Com que equipas técnicas trabalhará este papel?
- Como as conclusões júnior são revistas e treinadas?

## 28. Modelos, Glossário, Índice e Referências

- Estruturas de trabalho reutilizáveis, termos importantes e pontos de partida autoritários.\*

## # 28.1 Registro de risco mínimo

- **Campo\*\* \* Entrada\*\***  
ID de risco e proprietário Objectivo / activo “Evento e condição de ameaça”  
Consequências Controlos existentes
- Litígio e impacto O risco actual O titular do tratamento e da acção ☐  
Risco residual e aceitação Data de revisão

## # 28.2 Papel de teste de controle

- **Campo\*\* \* Entrada\*\***
  - Critérios e controlo Âmbito de aplicação e período • Proprietário e sistemas • Verificação da população e da completude Exemplo e justificação Procedimento realizado • Provas inspeccionadas Excepções Conclusão e limitação
- Correção e reteste

## # 28.3 Glossário

\* \* \* \* \*

• Anexo A • Conjunto de referência de 93 controlos de segurança da informação em ISO/IEC 27001:2022. . CIA . . Confidencialidade, integridade e disponibilidade. O cumprimento de uma exigência. ☐ Controlo ☐ Medida que modifica ou mantém o risco. - Acção correctiva - Acção que aborda a causa de uma não conformidade para prevenir a recorrência. Informações documentadas A organização deve controlar e manter ou reter. ☐ Parte interessada; Pessoa ou organização que pode afetar, ser afetada ou perceber-se afetada por uma decisão ou atividade. ☐ Sistema de gestão da segurança da informação. Não-conformidade Não-conformidade Risco residual . Risco remanescente após o tratamento. O proprietário do risco é uma pessoa ou entidade responsável e autorizada a gerir um risco. (SoA ) Declaração de Aplicabilidade. Gestão de topo ☐ Pessoa ou grupo que dirige e controla a organização no mais alto nível dentro do escopo.

## # 28.4 Índice de assuntos

### Sujeito Capítulo

☐ Controlos do anexo A Auditoria ☐ Certificação Emenda Climática 1, 2, 6, 21 • Acção correctiva ☐ Evidências ☐ Partes interessadas Analistas júnior Revisão de gestão , 11, 20 , ☐ Métricas 11, 18 • Ferramentas de código aberto • Avaliação e tratamento de riscos Âmbito de aplicação Declaração de Aplicabilidade Fornecedores 13, 18, 23

## # 28.5 Referências oficiais

ISO/IEC 27001:2022 visão geral

ISO/IEC 27001:2022/Amd 1:2024

ISO/IEC 27002:2022 visão geral

ISO/IAF comunicação sobre alterações climáticas

ISO certification overview

## ISO/IEC 27000 family

**Lembramento final:** Compra ou acesso legal às normas oficiais antes da implementação ou avaliação. Confirme edições atuais, emendas, acreditação, escopo de certificação, requisitos legais, contratos, tecnologia, ameaças e mudança organizacional. ☐

---

---

---